Name: Ahmed Shahid
Batch: AI-powered Cybersecurity
Date: 18 October 2026

ASSESSMENT 01: SECURITY FOUNDATIONS

Task A | Secure a student account

A1 & A2: Risk Analysis and Controls

Risk	Asset	CIA impact	Control	Limitation
1. Short password reused on email and learning portal	Email and portal accounts	**Confidentiality & Integrity:** An attacker compromising one account can access private data and alter submissions in the other.	Use a Password Manager to generate and store strong, unique passphrases.	The manager's master password becomes a single point of failure; if compromised, access to all stored accounts is at risk.
2. Approving unexpected sign-in prompts	Authentication tokens and account access	**Confidentiality:** An approved prompt bypasses password security and can grant unauthorized access.	Transition to Number-Matching MFA so she must physically type a number shown on the login screen.	Unexpected prompts target human trust. If the user is pressured or tricked into typing the number anyway, the control fails.
3. Postponing device updates	Laptop operating system	**Integrity & Availability:** Leaves the OS exposed to exploits targeting known vulnerabilities.	Enable Automatic OS Updates to patch vulnerabilities before they are exploited.	Updates can force system restarts at inconvenient times and cannot protect against unknown (zero-day) flaws.

Risk	Asset	CIA impact	Control	Limitation
4. Keeping only one copy of the project	Project files	**Availability:** If the laptop is lost, stolen, or hardware fails, the data is permanently lost.	Implement automated Cloud Backups.	Requires a consistent internet connection, and corrupted synced files can overwrite healthy cloud files if not monitored.
5. Friend using the laptop under Mira's signed-in account	Active session and private files	**Confidentiality & Integrity:** The friend could intentionally or accidentally read or alter private data.	Create a separate standard, non-root user account for the friend to enforce strict user isolation.	It only works if the friend actually uses it and Mira remembers to lock her own screen when stepping away.

Prioritised Actions

1. **Implement a Password Manager with unique passwords.** Reused credentials make it easy for one compromised account to expose another. Protecting the email is particularly important as it is often used to recover other services.
2. **Transition to Number-Matching MFA and reject unexpected prompts.** This pairs with the first action because both significantly reduce the risk of an external attacker gaining unauthorized access.
3. **Create a separate non-root user account.** User isolation is a fundamental wall of system security. Different users must have their own distinct accounts so they cannot modify each other’s private files.

Updates and backups are secondary priorities; they protect against potential future data loss or exploits, whereas the first three controls address immediate account-access vulnerabilities.

A3: Authentication vs. Authorisation

Authentication verifies a user's identity, while authorisation determines what that verified user is permitted to do. When Mira enters her password and completes an MFA check, the portal uses those credentials to authenticate that she is genuinely Mira. Authorisation occurs after authentication. For example, based on standard permissions, Mira is authorised to view her own course materials and submit assignments, but she is strictly denied access to edit another student’s grades or view administrative records.

Task B | Analyse a suspicious message

B1. Warning Signs Analysis

This message contains several characteristics commonly associated with phishing and social engineering. It should be treated as suspicious until verified independently.

Warning sign (Quote)	Why it needs scrutiny
"FINAL WARNING - scholarship expires in 20 minutes"	The short deadline pressures the student to act quickly out of panic, leaving less time to check whether the message is genuine.
From `awards@campus-awards.example`, Reply-To `help@personal-awards.example`	The reply domain does not match the sender domain, and neither appears to be the official `campus.example` domain, raising questions about authenticity.
`https://campus-awards.example/verify`	The college normally uses `campus.example`, but this link directs the user to a different, suspicious domain (`campus-awards.example`), strongly indicating a deceptive lookalike page.
"enter your college password and OTP"	The message requests authentication secrets. Legitimate organizations will not ask a user to share their password or OTP via an email link.
"Reply with a photo of your identity card"	An identity card contains sensitive personal information. Sending it to an unverified recipient exposes the student to identity theft.

B2. Safe Verification Process

The student should not click the link or reply to the email. Instead, they should open the college's official portal directly or contact the scholarship office using phone numbers or emails obtained independently from the official website. The link `https://campus-awards.example/verify` uses HTTPS, which encrypts the connection, but it does not prove that the website belongs to the genuine college. A familiar display name can also be easily forged. Neither feature alone establishes authenticity.

B3. Response Plan

If a student has already entered their password and OTP, the following steps should be taken:

1. **Immediate containment:** Using a trusted device, access the genuine portal through a known official route and change the compromised password. If the password was reused elsewhere, change it on those sites too.
2. **Official reporting:** Contact the college's authorized IT/security team. Explain what was entered and approximately when. Never send the actual password or OTP to the support team during this report.

3. **Follow-up checks:** Review recent sign-in activity, account recovery details, and MFA settings for unauthorized changes. If an ID photo was sent, report that as well and follow official identity-protection advice.

B4. Missing Facts

From this message alone, we cannot establish whether the scholarship was genuinely approved. The visible "From" line and email contents can be easily spoofed. To verify the claim, the student must contact the authorized scholarship office directly using independently verified contact details.

Task C | Triage a sign-in alert

C1. Timeline

Time	Observation (what the log shows)	Interpretation (what I think happened)
09:00–09:01	student07 logged in from 192.0.2.10, the usual classroom IP. Password succeeded and MFA was approved. The student says they did not sign in after 09:05.	These events are consistent with a normal, legitimate sign-in through the usual classroom network. This provides a baseline for comparison.
10:14–10:15	Two failed password attempts from 198.51.100.23, an IP this account has not used before.	This raises concern that someone was actively trying to guess the password. Since the student confirms they were not signing in, this is likely unauthorized activity.
10:16–10:18	Password succeeded at 10:16. MFA was denied at 10:17, then approved at 10:18. The student says they approved a prompt around 10:18 to stop repeated requests.	A correct password was entered. The student's statement offers a plausible explanation for the approval, suggesting a potential MFA fatigue scenario.
10:20	A session was created from 198.51.100.23.	A session was established with the student’s access. This is consistent with a possible account compromise, though the identity of the person controlling the session remains unconfirmed.

C2. Explanation and Checks

Likely explanation: The account may have been accessed by an unauthorized person who obtained the password. After two failed attempts, a password attempt succeeded. The student's statement suggests that

approving the repeated prompt to make the requests stop may have contributed to the session being created. This explanation is plausible, but the logs do not conclusively prove how the password was obtained or who controlled the session.

Alternative explanation: The sign-in may have involved legitimate activity from a different network or device (like a VPN) that the student did not recognize or remember. While the student's statement makes this less consistent with the evidence, the possibility should not be dismissed without further checks.

The IP address does not settle the identity. An IP address identifies the network from which the requests originated, but it does not independently establish the identity of the person using it.

Two additional checks:

1. **Review authentication details:** Compare the User-Agent strings, browser details, and session records for the 09:00 login and the 10:14–10:20 attempts. A match with the student’s recognized device supports the alternative explanation, while a different device profile supports an unauthorized access theory.
2. **Verify circumstances with the student:** Ask whether the student was using a different network or VPN at that time. Additionally, check if they recently interacted with any suspicious links or fake login pages that could explain how the password was obtained.

C3. Response Actions for the IT Team

1. **Preserve evidence:** Secure relevant authentication logs, MFA records, and session details before they expire or are overwritten. This protects the reliability of the investigation.
2. **Contain the suspected compromise:** Revoke active sessions immediately and reset the potentially compromised password through the official process. This step reduces the possibility of continued unauthorized access.
3. **Assess scope and monitor:** Review what the suspicious session accessed or changed, restore any affected account settings, and monitor the account for further unusual activity.

C4. Incident Summary

The logs record two failed password attempts followed by a successful password event from 198.51.100.23. An MFA request was denied, another was approved, and a session was subsequently created at 10:20. The student denies signing in after 09:05 but confirms approving a prompt to stop repeated requests. These events indicate a possible account compromise, although the source IP does not identify the person responsible. The priority is to preserve evidence, revoke potentially compromised sessions, secure the account, and investigate the session records.

Task D | Review an AI security answer

D1. Correct unsafe claims

AI Claim	Correction & Explanation
"The email is safe because it uses HTTPS."	HTTPS encrypts information sent between a browser and a website, but it does not prove that a website is genuine. Fraudulent sites can also use HTTPS. Verify claims through an independently located official contact.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	The logs associate authentication events with this IP, but do not identify the person or show how the password was obtained. Stating it was "stolen" by a specific individual is an unsupported assumption.
"MFA prevents every account compromise."	MFA adds significant protection but does not guarantee an account cannot be compromised. A user may approve an unexpected prompt due to fatigue or be deceived by phishing.
"Delete the suspicious logs"	Preserve sign-in, MFA, and session logs. They establish event order, show possible compromise vectors, and support recovery. Deleting them destroys the evidence needed for a reliable investigation.
"...send the student's password to support so they can test it."	Never send passwords or OTPs to support. Passwords must remain confidential even when a request appears trustworthy; IT staff use administrative tools and do not need a user's actual password to secure an account.

D2. Better prompt

> *"Act as a cybersecurity analyst reviewing a fictional scenario. Analyse only the synthetic message, sign-in logs, and statements supplied. For each conclusion, clearly distinguish between directly observed facts, reasonable interpretations, and information that remains unknown. Do not claim that an IP address identifies a particular person or that a security control guarantees complete protection unless the evidence supports the claim. Never request or recommend sharing passwords or OTPs. Recommend safe, proportionate response actions prioritizing containment and evidence preservation."*

D3. Corrected advice

Security decisions must always be based on verified evidence rather than unconfirmed assumptions. For instance, while HTTPS encrypts network traffic, it absolutely does not prove a website is genuine; attackers frequently use HTTPS on fraudulent pages. Always verify requests through independently sourced official channels. Similarly, a source IP and a successful sign-in indicate where the network activity originated, but they do not identify a specific person or conclusively show how a password was obtained. While MFA

significantly strengthens account security, unexpected prompts must never be approved simply to stop repeated requests, as this is a common fatigue tactic. Students should keep all credentials private, never share them with support staff, and report suspicious activity promptly. This allows IT to preserve logs, revoke active sessions, and investigate the incident safely.

D4. Declarations

AI-Use Declaration: AI was used strictly as a formatting and proofreading assistant to organize the document structure. All technical reasoning and analysis are my own original work based on the course materials.

- **Reference Note 1: CISA Secure Our World.** This guidance supports the recommendation to use strong, unique passwords and MFA, while emphasizing that users must remain vigilant against phishing tactics that attempt to bypass these controls.
- **Reference Note 2: NIST-Generative AI Profile (AI 600-1).** This framework highlights the risk of AI confabulation, supporting the principle that AI-generated conclusions (such as treating an IP address as definitive proof of identity) must always be independently verified against factual evidence.